

QuoteCraft Architecture Review

Executive Summary

- QuoteCraft is a Silver-tier internal microservice handling Restricted data (PII + Financial), deployed on AlphaPaaS (AWS) with Azure-managed Postgres and AWS-managed Redis/EFS.
- Multiple critical gaps exist in security (secrets, network policies, encryption), availability (single-AZ resources, missing DR), and cost (oversized non-prod, provisioned EFS).
- Several policy breaches are tracked as backlog tickets but remain unresolved, including public DB access, plaintext Redis, and improper RBAC.
- Scalability is limited by in-memory rate limiting and lack of DB connection pooling, risking performance at forecasted peak loads.
- Immediate remediation is required for secrets handling, network exposure, and resource sizing to meet AlphaPaaS standards.

Findings

Cost

F-01: Non-production environment exceeds cost threshold

- Severity: Critical
- Dimension: Cost
- Evidence:
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "The FinOps team flagged in March 2026 that QuoteCraft's non-production environment is consuming approximately 35% of what production consumes."
- Policy reference: FIN-07
- Why it matters: Exceeding 20% spend triggers a FinOps review and risks budget approval.
- Remediation: Investigate non-prod resource sizing and scheduling; reduce footprint to $\leq 20\%$ of production.
- Confidence: High

F-02: Provisioned EFS throughput not justified

- Severity: High
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/efs.tf
- Quote: "Provisioned throughput. Originally set during the pilot when we thought PDF generation would be I/O bound. It isn't. Tracked in QC-211."
- Policy reference: FIN-06
- Why it matters: Unjustified provisioned throughput increases monthly storage costs.
- Remediation: Switch EFS to standard throughput unless a documented IOPS requirement exists.
- Confidence: High

F-03: S3 archive lacks lifecycle policy for cold storage

- Severity: Medium
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/s3.tf
- Quote: "# NB: No lifecycle configuration. Quote archives are kept in STANDARD storage class indefinitely. There was a ticket to add glacier transition (QC-134) but it was deprioritised."
- Policy reference: FIN-13
- Why it matters: Keeping archives in standard storage increases long-term costs.
- Remediation: Implement S3 lifecycle policy to transition archives to Glacier after 30 days.
- Confidence: High

F-04: Oversized Azure Postgres instance in non-prod

- Severity: Medium
- Dimension: Cost
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "Azure PostgreSQL Flexible Server ... SKU: GP_Standard_D16s_v3 (16 vCPU, 64 GB RAM) ... Non-production environment is consuming approximately 35% of what production consumes."
- Policy reference: FIN-09
- Why it matters: Non-prod DB should be $\leq 50\%$ of production size and paused on weekends.
- Remediation: Downsize non-prod Postgres and implement weekend pausing.
- Confidence: Medium

Security

F-05: Redis cache not encrypted in transit

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:infra/aws/elasticache.tf
- Quote: "transit_encryption_enabled = false ... NB: TLS in transit is not enabled. Enabling it would require an application change (rediss:// URL and CA bundle). Tracked in QC-176."

- Policy reference: ASC-03, ASC-05, DCH-04
- Why it matters: Unencrypted cache exposes Restricted data (PII) to interception risk.
- Remediation: Enable TLS for ElastiCache and update application to use redis://.
- Confidence: High

F-06: Azure Postgres accessible via public internet

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:infra/azure/postgres.tf
- Quote: "public_network_access_enabled = true ... There is a ticket to lock this down (QC-193) but it has not been scheduled."
- Policy reference: ASC-03, DCH-04
- Why it matters: Public access exposes Restricted data to external threats and breaches private connectivity requirements.
- Remediation: Disable public access and enforce Private Endpoint for all DB traffic.
- Confidence: High

F-07: RBAC Role grants wildcard permissions

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/rbac.yaml
- Quote: "apiGroups: [\"*\"] ... resources: [\"*\"] ... verbs: [\"*\"] ... this Role was copied from an earlier internal tool and never tightened."
- Policy reference: CKS-14
- Why it matters: Wildcard RBAC permissions violate least privilege and CIS benchmarks, risking privilege escalation.
- Remediation: Restrict Role to only required resources and verbs.
- Confidence: High

F-08: Long-lived AWS access keys used for EFS and Secrets Manager

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/secret-aws-keys.yaml
- Quote: "# Long-lived IAM user access keys ... There's a ticket to migrate to IRSA (QC-203) but it's not scheduled yet."
- Policy reference: ASC-06, CKS-10
- Why it matters: Long-lived credentials increase risk of compromise; workload identity federation is required.
- Remediation: Migrate to IRSA or equivalent workload identity for AWS access.
- Confidence: High

F-09: Bureau API client disables certificate verification

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:src/quotecraft/integrations/bureau.py
- Quote: "verify=False ... TODO(QC-189): migrate to verify=True once the Atlas production CA is added to the base image trust store."
- Policy reference: DCH-05
- Why it matters: Disabling certificate verification exposes data to man-in-the-middle attacks.
- Remediation: Add Atlas CA to trust store and enable certificate verification.
- Confidence: High

F-10: Secrets injected as environment variables

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "envFrom: ... secretRef ... env: ... valueFrom: secretKeyRef ... Using envFrom.secretRef or env.valueFrom.secretKeyRef to inject secrets as environment variables is prohibited for new deployments."
- Policy reference: CKS-11, DCH-07

- Why it matters: Secrets in environment variables risk disclosure via logs and process listings.
- Remediation: Mount secrets as file volumes using CSI driver or External Secrets Operator.
- Confidence: High

F-11: Application logs full quote payloads including PII

- Severity: Medium
- Dimension: Security
- Evidence:
- Source: app:src/quotecraft/api/quotes.py
- Quote: "# Log the full payload so Support can reproduce the failure. (Flagged in the Feb 2026 security spot-check; QC-188 will redact.)"
- Policy reference: DCH-06, DCH-11
- Why it matters: Logging PII violates data handling standards and creates audit risk.
- Remediation: Redact PII from logs and implement field masking.
- Confidence: High

Scalability

F-12: In-memory rate limiter not safe for multi-replica scaling

- Severity: High
- Dimension: Scalability
- Evidence:
- Source: app:src/quotecraft/middleware/rate_limit.py
- Quote: "Module-level singleton; NOT shared across pods ... horizontal scaling will be addressed in QC-201."
- Policy reference: ARS-14
- Why it matters: Rate limiting is inconsistent across pods, risking quota breaches and false positives at scale.
- Remediation: Externalise rate limiter state to Redis or another shared store.
- Confidence: High

F-13: Database connection pool not implemented

- Severity: High
- Dimension: Scalability
- Evidence:
- Source: app:src/quotecraft/db.py
- Quote: "# TODO(QC-142): migrate to psycopg_pool.ConnectionPool ... For now we open a connection per request; at low baseline traffic this is acceptable, but the capacity plan anticipates 400 req/s at peak which we have not yet stress-tested."
- Policy reference: ARS-06
- Why it matters: Opening a new DB connection per request risks exhaustion and degraded performance at peak load.
- Remediation: Implement a shared connection pool for Postgres.
- Confidence: High

F-14: Redis cache is single-AZ, not multi-AZ

- Severity: Medium
- Dimension: Scalability
- Evidence:
- Source: app:infra/aws/elasticache.tf
- Quote: "Nodes: 1 (single-AZ) ... Multi-AZ ElastiCache replication (QC-177)"
- Policy reference: ARS-18
- Why it matters: Single-AZ cache limits resilience and scalability; multi-AZ is required for Silver tier.
- Remediation: Deploy Redis as a replication group across multiple AZs.
- Confidence: Medium

Availability

F-15: Application deployment does not meet Silver tier replica and multi-AZ requirements

- Severity: Critical

- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "replicas: 1 ... nodeSelector: failure-domain.alpha.pas.com/zone: \"1\""
- Policy reference: ARS-02, ARS-05
- Why it matters: Silver tier requires minimum 3 replicas and multi-AZ distribution; single replica in one AZ risks outage.
- Remediation: Update deployment to ≥ 3 replicas with topology spread constraints across AZs.
- Confidence: High

F-16: Postgres lacks zone-redundant high availability

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:infra/azure/postgres.tf
- Quote: "# Zone-redundant HA is not configured ... The HA configuration has not yet been revisited since the initial pilot."
- Policy reference: ARS-18
- Why it matters: Single-zone DB is a breach for Silver tier; loss of AZ causes data unavailability.
- Remediation: Enable zone-redundant HA for Azure Postgres.
- Confidence: High

F-17: Disaster recovery exercise not performed

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "DR exercise: **not yet performed.** Scheduled for Q3 2026."
- Policy reference: ARS-20
- Why it matters: DR exercise is mandatory for Silver tier; lack of testing risks unproven recovery.
- Remediation: Schedule and execute DR exercise simulating AZ loss; document outcome.
- Confidence: High

F-18: Worker uses deprecated DeploymentConfig resource

- Severity: Medium
- Dimension: Availability
- Evidence:
- Source: app:deploy/openshift/worker-deploymentconfig.yaml
- Quote: "kind: DeploymentConfig ... The legacy DeploymentConfig resource MUST NOT be used for new deployments, and existing usage MUST be migrated at the next major release."
- Policy reference: ARS-03, ARS-23
- Why it matters: Deprecated resources risk unsupported behavior and must be migrated.
- Remediation: Migrate worker to apps/v1 Deployment resource.
- Confidence: High

Highest Priority Next Actions

1. Disable public access to Azure Postgres and enforce Private Endpoint for all DB traffic (F-06).
2. Enable TLS for ElastiCache Redis and update application to use rediss:// (F-05).
3. Restrict RBAC Role permissions to only required resources and verbs (F-07).
4. Update application deployment to ≥ 3 replicas with topology spread constraints across AZs (F-15).
5. Investigate and reduce non-production environment footprint to $\leq 20\%$ of production (F-01).

All findings are grounded in the cited evidence and AlphaPaaS policy clauses. Remediation actions are suitable for backlog tickets and must be prioritized to ensure QuoteCraft meets Silver-tier requirements for Restricted data.